Microsoft 365 Copilot Data-Protection Readiness — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 5

The problem . . . 5

The solution . . . 5

What is delivered . . . 5

Business value . . . 5

Boundaries . . . 5

1. Solution Overview — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 6

What this solution is . . . 6

Why this matters . . . 6

The remediation levers (what actually reduces Copilot exposure) . . . 7

The scope of "outcomes" (what this solution does and does not decide) . . . 7

Naming convention (used in every doc and script) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 8

2.1 Compliance licensing for the readiness controls (verify) . . . 8

2.2 Least-privilege Purview & SharePoint roles (GR §2) . . . 9

2.3 Purview auditing (unified audit log) on (GR §4) . . . 9

2.4 A sensitivity-label taxonomy and classification intent (GR §4, §5) . . . 9

2.5 In-scope SharePoint/OneDrive/Teams estate and Copilot rollout ring (GR §4, §6) . . . 9

2.6 SharePoint Advanced Management controls availability (verify) . . . 10

2.7 Pilot in simulation/test and change control (GR §6) . . . 10

2.8 Stakeholder ownership of the go/no-go (GR §5) . . . 10

Global Requirements — Microsoft Purview Solutions 10

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 11

2. Purview roles (least-privilege) and portal access . . . 11

3. Security & Compliance PowerShell + Graph toolchain . . . 11

4. Data sources & scope in scope . . . 12

5. Compliance, records, privacy & legal stakeholders . . . 12

6. A pilot scope and change control . . . 12

3. Implementation Guide — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 13

Step 0 — Confirm scope, licensing, roles, and connections (Assess) . . . 13

Step 1 — Discover SharePoint/OneDrive oversharing (Assess) . . . 13

Step 2 — Assess unlabeled sensitive content (Assess) . . . 14

Step 3 — Design the controls and agree the plan (Design) . . . 14
Step 4 — Configure & pilot labeling (Configure → Pilot) . . . 14
Step 5 — Configure & pilot DLP for Copilot (Configure → Pilot) . . . 15
Step 6 — Reduce SharePoint access & apply interim containment (Configure → Pilot) . . . 15
Step 7 — Validate the pilot (Validate) . . . 16
Step 8 — Expand, enforce, and record the go/no-go (Expand) . . . 16
5. Testing & Validation — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)
Gate 1 — Scope, licensing, roles, and connections (Step 0) . . . 17
Gate 2 — Oversharing baseline captured (Steps 1–2) . . . 17
Gate 3 — Labeling piloted safely (Step 4) . . . 17
Gate 4 — DLP for Copilot behaves as designed (Step 5) . . . 18
Gate 5 — SharePoint access reduced on pilot targets (Step 6) . . . 18
Gate 6 — Copilot honors the controls (behavioral spot-check, where Copilot is licensed) . . . 18
Gate 7 — Readiness go/no-go evidence complete (Step 8) . . . 19
Regression / recurring validation . . . 19
6. Troubleshooting — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 19
Connections & authentication . . . 19
Licensing & availability (the most common blocker) . . . 20
Discovery . . . 20
Labeling . . . 20
DLP for Copilot . . . 21
SharePoint access reduction & interim containment . . . 21
Enforcement & go/no-go . . . 21
7. Best Practices — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 22
Sequence and safety . . . 22
Labels are the primary Copilot control . . . 22
Fix access, don't just hide it . . . 22
Roles, separation of duties, and change control . . . 23
Governance boundary . . . 23
Operate it as a program, not a project . . . 23
8. Deliverables Summary — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview) 23
What you receive . . . 23
Documentation set . . . 24
Automation — 5 PowerShell tools . . . 24
Named artifacts (traceable end to end) . . . 25
Outcome . . . 25

Assumptions & boundaries 26
Appendix A — PowerShell Scripts 27

Executive Summary — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

The problem

Microsoft 365 Copilot surfaces whatever a user can already access. The day Copilot is enabled, every over-shared file, message, and site a user technically has access to — much of it unlabeled and shared with "Everyone Except External Users" or open to broad groups — becomes one prompt away. Access that was safe only through obscurity becomes instantly discoverable. Left unaddressed, this is both a compliance gap and a data-risk exposure at the moment of highest visibility.

The solution

A repeatable, self-guided **remediation playbook** that makes data safe **before Copilot sees it** — delivered end to end in **Microsoft Purview** with the Purview portal, the Microsoft 365 / SharePoint admin centers, Security & Compliance PowerShell, and Microsoft Graph:

- **Discover** the oversharing and the unlabeled sensitive content that drives Copilot exposure.
- **Remediate** it with the three levers that actually shrink exposure: **sensitivity labels** (default/

auto-labeling and encryption/usage rights that Copilot honors), **DLP for Microsoft 365 Copilot** (keep the most sensitive content out of AI responses), and **SharePoint access controls** (remove broad grants; fence off not-yet-cleaned sites with interim Restricted Content Discovery / Restricted SharePoint Search).

- **Pilot** every high-impact change in **simulation / test / disabled** mode, **validate** against

explicit pass/fail gates, then **enforce and expand** — and record a defensible **go / no-go** readiness decision.

This is distinct from "DSPM for AI," which *shows* exposure and recommends fixes: this is the hands-on work of *fixing and evidencing* it. Where DSPM for AI exists in the tenant, it is read as one input.

What is delivered

Eight guides (overview, requirements, implementation, testing, troubleshooting, best practices, deliverables, this summary) and **five safe-by-default PowerShell tools** (read-only or -WhatIf/ simulation until you commit) covering discovery, remediation, validation, and the go/no-go report — all white-label, no secrets in code.

Business value

- **Close the Copilot oversharing gap** before broad rollout, at a fraction of consulting cost.
- **Defensible readiness** — a before/after, controls-applied, validated go/no-go record for leadership.
- **No collaboration broken** — every control is piloted in simulation/test and validated first.
- **Owned, not outsourced** — configured entirely in your own Purview/Microsoft 365 tenant.

Boundaries

Microsoft Purview capabilities are **licensing-/plan-dependent and evolving** (E5 / E5 Compliance, SharePoint Advanced Management, Microsoft 365 Copilot; some controls in preview) — availability is flagged "verify your licensing/tenant," never assumed. **Regulatory, records, and legal determinations — including the final go/no-go decision — remain with your compliance, records, privacy, and legal functions**; this package supplies the technical method and the evidence.

1. Solution Overview — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

What this solution is

Microsoft 365 Copilot surfaces whatever a user can already access. The moment Copilot is switched on, every file, message, and site that user *technically* has access to — including content that was over-shared and never actively found — becomes one prompt away. This solution is the **remediation playbook that makes your data safe *before* Copilot sees it**: a repeatable, self-guided way to **discover oversharing and then remediate it** with Microsoft Purview sensitivity labels, Data Loss Prevention (DLP), and SharePoint access controls, so Copilot only surfaces appropriate data.

It is delivered end to end in the **Microsoft Purview portal** (`https://purview.microsoft.com`), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — with no third-party tooling. Every high-impact change (a new label policy, a DLP policy, an auto-labeling policy, a sharing restriction) is **piloted in simulation / test / disabled mode first**, validated against pass/fail gates, and only then enforced and expanded.

> ***How this differs from "DSPM for AI."*** *Data Security Posture Management for AI is the **telemetry and posture surface** — it *shows* what AI can reach and recommends fixes. **This solution is the hands-on remediation playbook** you run against that signal: the ordered work of discovering the oversharing, standing up the labels/DLP/access controls that shrink it, piloting and validating each control, and producing a defensible **go / no-go readiness decision** before broad Copilot rollout. Use DSPM for AI to *see*; use this solution to *fix and evidence*. Where DSPM for AI is present in your tenant, this solution reads it as one input; where it is not, the discovery scripts and portal steps here still give you the oversharing picture.*

Why this matters

- **Copilot inherits access, not intent.** It respects existing permissions exactly — so a document shared with "Everyone except external users," or a site open to a broad group, is fair game for Copilot to summarize and cite. Access that was harmless-by-obscurity becomes discoverable.
- **Copilot honors sensitivity-label protection.** If content carries a sensitivity label whose encryption denies the user usage rights, Copilot will not surface or summarize it, and cited content inherits the highest-priority label of its sources. Labeling is therefore a *direct* Copilot control, not just a classification exercise — which is exactly why getting labels right before rollout matters.
- **Oversharing remediation is high-impact.** Broad sharing changes, new DLP, and auto-labeling can disrupt legitimate collaboration if enforced blindly — so every reduction here is piloted in simulation/test and validated before enforcement.

- **"Ready" must be evidenced, not asserted.** Leadership needs a defensible answer to "is our data safe

for Copilot?" This solution produces that evidence: a before-state, the controls applied, the validation results, and a recorded go/no-go.

The remediation levers (what actually reduces Copilot exposure)

- **Sensitivity labels — coverage & protection.** Default and (where policy requires) mandatory labeling

so content is classified; **encryption/usage rights** on protected labels so Copilot honors "who may read this"; **container labeling** on SharePoint sites, Teams, and Microsoft 365 Groups to control privacy, external sharing, and the default sharing link. *(Availability of container labeling and mandatory labeling is licensing-dependent — verify in your tenant.)*

- **Auto-labeling (simulation first).** Service-side auto-labeling policies that classify sensitive

content at rest across SharePoint/OneDrive/Exchange, run in **simulation** so you see what *would* be labeled before anything is applied.

- **DLP for Microsoft 365 Copilot.** A DLP policy scoped to the **Microsoft 365 Copilot** location that

prevents Copilot from processing/summarizing content carrying specified sensitivity labels — keeping the most sensitive material out of AI responses. *(Feature availability is evolving/licensing-gated — verify the Copilot DLP location exists in your tenant.)*

- **SharePoint access remediation.** Reducing the actual access surface: removing broad "Everyone Except

External Users" (EEEU) grants, tightening site/sharing scope, and — as documented interim controls — **Restricted SharePoint Search** and **Restricted Content Discovery** to fence off not-yet-remediated sites from Copilot and org-wide search while you do the real cleanup. *(These SharePoint controls are delivered via SharePoint admin / SharePoint Advanced Management and are licensing-dependent — verify.)*

The scope of "outcomes" (what this solution does and does not decide)

This solution delivers the **technical method and the evidence** — how to discover oversharing and configure labels, DLP, and access controls, piloted and validated. It does **not** make **regulatory, records, or legal determinations**: which data is "sensitive," what an acceptable Copilot-exposure level is, what must be retained or restricted, and any records/legal-hold obligations are **deferred to your compliance, records, privacy, and legal functions**. You provide the configuration and the evidence; they own the determination and the final go/no-go sign-off.

Naming convention (used in every doc and script)

Every artifact this solution creates or exports is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal so a reader can trace one artifact end to end.

Artifact	Name
Readiness scope & connection-health export	`Copilot Readiness – Tenant – Scope`
SharePoint/OneDrive oversharing discovery export	`Oversharing – Estate – Discovery`

Artifact	Name
Unlabeled sensitive-content assessment export	`Unlabeled Sensitive – Estate – Assess`
Pilot default-labeling policy	`Default Labeling – Users – Pilot`
Pilot auto-labeling (simulation) policy	`Auto-Label Sensitive – Pilot – Simulation`
Pilot DLP-for-Copilot (test) policy	`DLP for Copilot – Pilot – Test`
Prioritized SharePoint access-reduction list	`Site Access Reduction – Sites – Pilot`
Readiness go/no-go decision record	`Copilot Readiness – Tenant – GoNoGo`
Recurring readiness-review cadence tag	`Copilot Readiness Review – Tenant – Recurring`

The standard deployment model

> *Confirm scope/licensing/roles → discover oversharing and unlabeled sensitive content → design the label/DLP/access controls with stakeholders → configure and **pilot every control in simulation/test/disabled** → validate against gates → **expand to enforce**, record the go/no-go, and review on a recurring cadence. Pattern: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).***

2. Requirements Guide — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

Verify **every** requirement before configuring. Each entry gives **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant compliance licensing, least-privilege Purview roles, the Security & Compliance PowerShell + Graph toolchain, in-scope workloads, compliance/ records/privacy/legal stakeholders, and a pilot scope + change control) are in `global-requirements-purview.md` (GR §1–§6) — this guide adds the **Copilot-readiness-specific** prerequisites and points back to the relevant GR item.

> ***Availability caveat.** Several controls below (DLP for Microsoft 365 Copilot, Restricted SharePoint Search, Restricted Content Discovery, SharePoint Advanced Management data-access-governance reports, container and mandatory labeling) are **licensing-/tenant-dependent** and some are **evolving or in preview**. Where this guide names a portal path, policy location, or cmdlet, **confirm it exists in your tenant** rather than assuming — items marked *(verify)* are "verify in your tenant" by design.*

2.1 Compliance licensing for the readiness controls (verify)

Description: The licensing the remediation levers require — commonly **Microsoft 365 E5** or the **E5 Compliance** add-on for advanced DLP, auto-labeling, and container labeling; **SharePoint Advanced Management (SAM)** for the Data Access Governance oversharing reports, site access reviews, Restricted Content Discovery, and Restricted Access Control; and, for the AI controls, a **Microsoft 365 Copilot** license (SAM is reported to be included with Copilot — *verify in your tenant*). The **DLP for Microsoft 365 Copilot** location availability is evolving and licensing-gated *(verify)*. **Why:** These controls are plan-gated; the Copilot DLP location, SAM reports, and auto-labeling simply will not appear without the right plan.

Verify: In the M365 admin center confirm the subscriptions/add-ons; in the Purview portal confirm **Information Protection**, **Data Loss Prevention**, and (if used) **DSPM for AI** render; in the SharePoint admin center confirm the SAM reports/controls are present. Run `AICOPILOT-ReadinessScope.ps1` (read-only) to enumerate the labels, DLP, and auto-labeling features available to feed remediation. **Implement:** Assign/purchase the required licensing before starting; where a control is absent, note it out of scope and proceed with the licensed subset (e.g. do access remediation via native SharePoint sharing controls if SAM is not licensed).

2.2 Least-privilege Purview & SharePoint roles (GR §2)

Description: Membership in the least-privilege role groups the work needs: **Information Protection Admin** (labels, label policies, auto-labeling), **Compliance Administrator / DLP** role for DLP policies, and **SharePoint Administrator** for the SharePoint access controls (DAG reports, RSS, RCD, site access). Reading DSPM for AI needs the matching information-protection/DSPM role. Confirm the **exact current role-group names** in your portal. **Why:** Purview and SharePoint use fine-grained roles; creating a label vs. a DLP policy vs. changing site access each need the matching role, and separation of duties should be preserved. **Verify:** Purview portal → **Settings / Roles & scopes** → **Role groups** for the compliance roles; Microsoft 365 admin center → roles for **SharePoint Administrator**. Confirm you can open Information Protection, DLP, and the SharePoint admin center without an access error. **Implement:** Assign the least-privilege role groups under change control; reserve Global/Compliance Administrator for initial enablement only.

2.3 Purview auditing (unified audit log) on (GR §4)

Description: The **unified audit log** enabled, so Copilot interactions, sharing events, and label activity are recorded and available to DSPM for AI, activity explorer, and the validation reports. **Why:** Readiness evidence (what Copilot touched, what changed) and DSPM for AI reporting draw on auditing; without it you cannot validate or evidence outcomes. **Verify:** Purview portal → **Audit** shows searching is on; `AICOPILOT-ReadinessScope.ps1` reports the audit state. **Implement:** Turn on auditing (it may take time to fully populate) before relying on the reports.

2.4 A sensitivity-label taxonomy and classification intent (GR §4, §5)

Description: An agreed **sensitivity-label taxonomy** (or a decision to use a starter set) and a **classification intent** — which labels denote content that must be protected from broad access / kept out of Copilot — approved by compliance/privacy stakeholders. Protected labels that Copilot should honor must carry **encryption with usage rights**. **Why:** Labels are the primary Copilot control (Copilot honors label encryption/usage rights, and DLP for Copilot keys off labels). Auto-labeling and DLP have nothing to act on without a taxonomy and intent. **Verify:** Purview portal → **Information Protection** → **Sensitivity labels**; confirm the labels and, for protected ones, that encryption/usage rights are configured. Confirm the intent with stakeholders (GR §5). **Implement:** If the taxonomy is thin or absent, define a minimal starter taxonomy and the "keep out of Copilot" intent with stakeholders **before** authoring auto-labeling/DLP — a thin taxonomy is itself an early finding. (Full taxonomy *design* is a separate exercise; here you need enough to remediate.)

2.5 In-scope SharePoint/OneDrive/Teams estate and Copilot rollout ring (GR §4, §6)

Description: The **workloads and sites in scope** for oversharing discovery (SharePoint, OneDrive, Teams/Groups) and the **Copilot rollout ring** — the pilot population who will get Copilot first, which doubles as the readiness pilot scope. **Why:** Oversharing discovery and remediation key off the in-scope sites; piloting readiness on the same ring that gets Copilot first keeps the pilot representative. **Verify:** Confirm the in-scope sites/workloads and the named Copilot pilot ring with stakeholders. **Implement:** Define the scope and the rollout ring before discovery; if Copilot is not yet deployed, you are in **pre-adoption** mode — the goal is to remediate oversharing *before* enabling Copilot.

2.6 SharePoint Advanced Management controls availability (verify)

Description: Availability of the SharePoint access controls this playbook uses: **Data Access Governance (DAG)** oversharing reports (sharing links, "Everyone Except External Users," sensitivity labels applied), **site access reviews**, **Restricted Content Discovery (RCD)** (excludes a site's content from Copilot and org-wide search), **Restricted Access Control (RAC)** (limits a site to a named group), and **Restricted SharePoint Search (RSS)** (an interim allow-list of up to 100 sites for search/Copilot). *(All are SAM/SharePoint-admin features; availability and exact names are tenant-dependent — verify.)* **Why:** These are the access-remediation and interim-containment levers; RSS/RCD let you fence off not-yet-cleaned sites from Copilot while you remediate properly. **Verify:** SharePoint admin center → **Reports / Settings / Data access governance**; confirm the reports and controls are present. RSS state is checked via SharePoint Online Management Shell (`Get-SPOTenantRestrictedSearchMode`) — *documented method, run under SharePoint admin*. **Implement:** If SAM is unlicensed, remediate access via native SharePoint site/sharing settings and Microsoft Graph permission review instead, and note the interim controls as unavailable.

2.7 Pilot in simulation/test and change control (GR §6)

Description: A confirmed **pilot ring**, that **simulation/test/disabled** mode is available for labeling and DLP, and a **change window/approval path** — no label policy, auto-labeling policy, DLP policy, or sharing restriction is enforced before it is piloted and validated. **Why:** Labels, DLP, and access changes are high-impact; the house model mandates Assess→Design→Configure→**Pilot (simulate/test)**→Validate→Expand(enforce). **Verify:** Confirm the named pilot ring, that auto-labeling supports **simulation** and DLP supports **test/disabled**, and the change-control path. **Implement:** Define the pilot and agree change control before enforcing anything.

2.8 Stakeholder ownership of the go/no-go (GR §5)

Description: Named **compliance, records, privacy, security, and legal** owners who will approve the final **Copilot readiness go/no-go**, and agreement that they own the determination of "acceptable exposure." **Why:** The decision to enable Copilot broadly is a governance decision, not a technical one; this solution supplies the evidence, the owners make the call. **Verify:** Confirm the named approvers and the criteria they will judge against. **Implement:** Identify the owners and capture the readiness criteria before the pilot so the go/no-go is decided against agreed gates, not improvised.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication

compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.

- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant

governance functions.*

3. Implementation Guide — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

Follow these steps **in order**. Discovery, remediation, and validation are automated with Security & Compliance PowerShell (`Connect-IPPSSession`) and Microsoft Graph; portal steps are done in the **Microsoft Purview portal** (`https://purview.microsoft.com`), the **Microsoft 365 admin center**, and the **SharePoint admin center**. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **Every high-impact change is piloted in simulation/test/disabled first** — the scripts default to `-WhatIf` and to simulation/test mode, and no write happens without `-Commit`.

> ***Model:*** *confirm scope, discover the oversharing and unlabeled sensitive content, design the controls with stakeholders, configure and* ***pilot each control in simulation/test****, validate against gates, then expand to enforce, record the go/no-go, and review on a recurring cadence. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce). Portal-path caveat.*** *Purview and SharePoint blades evolve and several controls are licensing-gated or in preview; the paths and policy locations below are the current map. If a blade, location, or cmdlet differs in your tenant, use the closest documented equivalent and* ***confirm before acting*** *— do not assume a path that is not present.*

Step 0 — Confirm scope, licensing, roles, and connections (Assess)

1. Run `AICOPILOT-ReadinessScope.ps1` (read-only). It confirms your `Connect-IPPSSession` /

`Connect-MgGraph` sign-in, reports whether **auditing** is on, and enumerates the licensing-dependent levers available (sensitivity labels, label policies, DLP policies, auto-labeling policies) — resolving Requirements 2.1–2.4. It writes `Copilot Readiness – Tenant – Scope`.

1. In the Purview portal confirm **Information Protection**, **Data Loss Prevention**, and (if present)

DSPM for AI render; in the SharePoint admin center confirm the SAM data-access-governance reports and controls are visible (Requirement 2.6). Note any capability that is absent so you scope around it.

1. Confirm the **Copilot rollout ring / pilot scope** and the change window (Requirements 2.5, 2.7)

before any configuration.

Pass/fail: Sign-in succeeds, auditing is on, the levers are enumerated, pilot ring and change window agreed. **Rollback:** None — read-only.

Step 1 — Discover SharePoint/OneDrive oversharing (Assess)

1. Run `AICOPILOT-OversharingDiscovery.ps1` (read-only, Microsoft Graph). It inventories the in-scope

SharePoint sites and surfaces the **oversharing signals** that make content reachable by Copilot: sites/items shared with **"Everyone Except External Users" (EEEU)** or organization-wide, broad **sharing links**, and large-audience access. It writes `Oversharing – Estate – Discovery`.

1. Where **SharePoint Advanced Management** is licensed (Requirement 2.6), also run the **Data Access

Governance** reports in the SharePoint admin center (sharing links, EEEU, sensitivity labels applied) and reconcile them with the script output — the DAG reports are the authoritative tenant view; the script gives you a portable, filterable export.

1. Rank the results: broadly-shared sites are the priority targets, especially those that (per Step 2)

also hold unlabeled sensitive content.

Pass/fail: The discovery export lists in-scope sites with their oversharing signal; top targets can be named. **Rollback:** None — read-only.

Step 2 — Assess unlabeled sensitive content (Assess)

1. Run `AICOPILOT-OversharingDiscovery.ps1 -IncludeSensitive` (read-only). It appends the **sensitive

information types **in scope and the** label-coverage** picture (which in-scope locations have little or no labeling) into `Unlabeled Sensitive – Estate – Assess`, giving a portable record of where sensitive-but-unlabeled content is most likely concentrated.

1. Where **DSPM for AI** is present, cross-read its **data-access** and **sensitive-interactions** views

as corroborating telemetry — this solution *remediates* what those views reveal.

1. Cross-read Steps 1–2: **broadly-shared sites holding unlabeled sensitive content are the top Copilot

oversharing risk** and drive the remediation order.

Pass/fail: The unlabeled-sensitive export is written; the top "broad + sensitive" targets are named. **Rollback:** None — read-only.

Step 3 — Design the controls and agree the plan (Design)

1. With compliance/records/privacy/legal stakeholders (GR §5, Requirement 2.8), agree, for the pilot

ring: (a) the **default label** to apply, and whether **mandatory labeling** is in scope; (b) which labels denote "**keep out of Copilot**" and therefore drive DLP for Copilot; (c) the **auto-labeling** conditions (which sensitive info types → which label); and (d) the **site access-reduction** list and whether interim **RSS/RCD** containment is warranted while cleanup proceeds.

1. Record this as the design baseline. **The determinations (what is "sensitive," acceptable exposure,

what must be restricted) are the stakeholders'**; you provide the method and will implement the agreed technical changes and pilot them.

Pass/fail: The agreed control set and access-reduction list are recorded. **Rollback:** None — design only.

Step 4 — Configure & pilot labeling (Configure → Pilot)

1. **Default labeling (pilot).** In the Purview portal → **Information Protection** → **Label policies**,

publish a label policy scoped to the **pilot ring** that sets a **default label** (and mandatory labeling if agreed). Name it `Default Labeling – Users – Pilot`. This ensures new/edited content is classified for the

pilot population. *(Mandatory labeling availability is licensing-dependent — verify.)*

1. **Auto-labeling (simulation).** Run

`AICOPILOT-Remediation.ps1 -Action AutoLabel -Scope "Auto-Label Sensitive – Pilot – Simulation"` (defaults to `-WhatIf`; add `-Commit` to create it). With `-Commit` it creates the auto-labeling policy `Auto-Label Sensitive – Pilot – Simulation` in **simulation mode** — it labels *nothing* yet, it only shows what it *would* label against the agreed conditions. This closes label-coverage gaps without risk.

Pass/fail: The pilot label policy is published to the ring; the auto-labeling policy exists in **simulation** (labels nothing yet). **Rollback:** Unpublish the label policy and delete the simulation auto-labeling policy — no content was changed.

Step 5 — Configure & pilot DLP for Copilot (Configure → Pilot)

1. Run `AICOPILOT-Remediation.ps1 -Action DlpForCopilot -Scope "DLP for Copilot – Pilot – Test"` with

`-Commit` to create the DLP policy `DLP for Copilot – Pilot – Test` in **test/disabled** mode, scoped to the **Microsoft 365 Copilot** location and conditioned on the agreed "keep out of Copilot" sensitivity labels — so Copilot will not process/summarize that content once enforced.

1. **Verify the Copilot DLP location name in your portal** — the script parameterizes the location and

does not assume it, because the Copilot DLP location is evolving/licensing-gated *(verify)*. If the location is not present in your tenant, keep the "keep out of Copilot" content controlled via label **encryption/usage rights** (which Copilot honors) plus site access reduction (Step 6) as the available equivalent, and note DLP-for-Copilot as pending.

Pass/fail: The DLP-for-Copilot policy exists in **test/disabled** on the Copilot location — nothing is enforced yet. **Rollback:** Delete the test policy; no interaction was blocked.

Step 6 — Reduce SharePoint access & apply interim containment (Configure → Pilot)

1. Run `AICOPILOT-Remediation.ps1 -Action SiteAccessList -Scope "Site Access Reduction – Sites – Pilot"`

(read-only by design). It produces the **prioritized site access-reduction list** from `Oversharing – Estate – Discovery` — the sites to tighten first. It does **not** silently change sharing.

1. For each pilot target, reduce access via the **documented SharePoint methods** (run under SharePoint

Administrator): remove broad **EEEU**/org-wide grants and over-broad sharing links; where SAM is licensed, apply **Restricted Access Control (RAC)** to limit a site to a named group, and use **site access reviews** to drive owner cleanup.

1. **Interim containment while you clean up.** Where not-yet-remediated sites must be fenced off from

Copilot immediately, apply the documented SharePoint controls: **Restricted Content Discovery (RCD)** on specific sites (excludes their content from Copilot and org-wide search), or tenant-wide **Restricted SharePoint Search (RSS)** — an interim allow-list of up to 100 sites — via the SharePoint Online

Management Shell (`Set-SPOTenantRestrictedSearchMode`, `Add-SPOTenantRestrictedSearchAllowedListUrls`). Treat RSS/RCD as **temporary stopgaps**, not the end state — the goal remains fixing the underlying access. *(RSS/RCD availability is SAM/tenant dependent — verify.)*

Pass/fail: The access-reduction list is produced; pilot-site access is tightened and/or interim RCD/RSS containment is applied and recorded. **Rollback:** Restore the prior sharing on any site where a change broke legitimate access; turn RSS off (`Set-SPOTenantRestrictedSearchMode -Mode Disabled`) or remove RCD to revert containment.

Step 7 — Validate the pilot (Validate)

1. Let simulation/test run the agreed window. In the portal review the auto-labeling **simulation

results **(what it would label) and the DLP-for-Copilot** test** matches (what it would keep out of Copilot) for false positives.

1. Run `AICOPILOT-Validation.ps1` (read-only). It confirms the pilot label policy is published, the

auto-labeling policy is in **simulation**, the DLP-for-Copilot policy is in **test/disabled**, and re-reads the oversharing signal for the pilot sites to confirm it is lower after Step 6.

1. Confirm with stakeholders that the simulated outcomes match intent (no legitimate collaboration

broken, no over-blocking of Copilot on appropriate content). See Testing (doc 5) for the explicit gates.

Pass/fail: Simulation/test results reviewed, acceptable false-positive rate, pilot oversharing reduced. **Rollback:** If results are wrong, adjust the policy conditions / access changes and re-pilot — enforce nothing until the gate passes.

Step 8 — Expand, enforce, and record the go/no-go (Expand)

1. Only after the pilot gate passes: turn the auto-labeling policy from **simulation** to **on**, and the

DLP-for-Copilot policy from **test** to **enforce**, and widen the label policy and access reduction beyond the pilot ring — as a deliberate, change-controlled step. `AICOPILOT-Remediation.ps1 -Action Enforce -Commit` performs the mode change on the named policies (still gated behind `-Commit`).

1. Complete the broad **SharePoint access reduction** on the remaining oversharing targets under change

control, and remove any interim **RSS/RCD** containment once the underlying access is fixed.

1. Run `AICOPILOT-ReadinessReport.ps1` (read-only) to compile the **go/no-go readiness record**

`Copilot Readiness – Tenant – GoNoGo` — the before/after oversharing, the controls applied and their state, and the residual risk — for stakeholder sign-off (Requirement 2.8). **The go/no-go decision is theirs**; the report is the evidence.

1. Stand up the recurring review: tag the cadence `Copilot Readiness Review – Tenant – Recurring` and

schedule the read-only `ReadinessScope` → `OversharingDiscovery` → `Validation` → `ReadinessReport` chain (e.g. monthly) so readiness stays measured as data, sharing, and Copilot usage change.

Pass/fail: Controls enforced at broad scope, oversharing reduced on re-measure, go/no-go recorded and signed off, recurring review scheduled. **Rollback:** Return any enforced policy to simulation/test (or delete it) and restore prior sharing on any site where enforcement caused an issue; re-apply RSS/RCD containment if broad rollout must pause. The discovery and go/no-go exports are the before-state to restore toward.

5. Testing & Validation — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

Testing proves the remediation actually reduces Copilot exposure **without breaking legitimate collaboration** — before anything is enforced tenant-wide, and before the go/no-go is signed. Every gate below is validated on the **pilot ring** first, with policies in **simulation/test/disabled**, and each has an explicit **pass/fail** and a **rollback**. Run `AICOPILOT-Validation.ps1` (read-only) to collect the machine-checkable evidence; confirm the human-judgement gates with stakeholders.

> ***Determination boundary.*** *These gates confirm the controls are *configured and behaving as designed*. Whether the residual exposure is *acceptable* is a compliance/privacy/legal determination (Requirement 2.8) — testing supplies the evidence, stakeholders make the call.*

Gate 1 — Scope, licensing, roles, and connections (Step 0)

- **Test:** Run `AICOPILOT-ReadinessScope.ps1`. Confirm sign-in, auditing on, and the available

levers (labels, label policies, DLP, auto-labeling) enumerated; confirm the pilot ring and change window are agreed.

- **Pass:** All connect; auditing on; levers listed; pilot ring recorded.
- **Fail / rollback:** Missing licensing or role → resolve per Requirements 2.1–2.2 before proceeding

(read-only; nothing to undo).

Gate 2 — Oversharing baseline captured (Steps 1–2)

- **Test:** `Oversharing – Estate – Discovery` and `Unlabeled Sensitive – Estate – Assess` are written

and list in-scope sites with their oversharing signal and label-coverage picture; where SAM is licensed, the SharePoint DAG reports reconcile with the export.

- **Pass:** Both exports present; top "broad + sensitive" targets can be named as the before-state.
- **Fail / rollback:** Empty/partial export → check Graph permissions and in-scope site list, re-run

(read-only).

Gate 3 — Labeling piloted safely (Step 4)

- **Test:** The pilot label policy `Default Labeling – Users – Pilot` is published to the ring only; the

auto-labeling policy `Auto-Label Sensitive – Pilot – Simulation` exists in **simulation** and has labeled **nothing**. Review the simulation results for false positives (content that would be mislabeled).

• **Pass:** Default labeling applies for the pilot ring; simulation shows a sensible would-label set with an acceptable false-positive rate; no auto-label has been applied.

• **Fail / rollback:** High false positives → tighten the auto-labeling conditions and re-simulate; unpublish the label policy / delete the simulation policy to revert (no content changed).

Gate 4 — DLP for Copilot behaves as designed (Step 5)

• **Test:** The DLP policy `DLP for Copilot – Pilot – Test` exists in **test/disabled** on the **Microsoft 365 Copilot** location, conditioned on the agreed labels. Review the **test** matches: content that *would* be kept out of Copilot. Confirm appropriate content is **not** over-matched. *(If the Copilot DLP location is absent in your tenant — verify — this gate is met instead by confirming label encryption/usage rights keep the content out of Copilot, plus Gate 5 access reduction.)*

• **Pass:** Test policy present on the Copilot location; matches align with the "keep out of Copilot" intent; no excessive over-match on appropriate content.

• **Fail / rollback:** Over/under-matching → adjust the label conditions and re-test; delete the test policy to revert (nothing was blocked).

Gate 5 — SharePoint access reduced on pilot targets (Step 6)

• **Test:** `Site Access Reduction – Sites – Pilot` was produced; the pilot targets have had broad **EEEU**/org-wide grants and over-broad sharing links removed (and/or RAC applied), and any interim **RCD/RSS** containment is in place and recorded. Re-run the discovery on the pilot sites.

• **Pass:** The pilot sites' oversharing signal is measurably lower; interim containment (if used) is recorded as temporary; **no legitimate access was broken** (confirm with site owners/users).

• **Fail / rollback:** Legitimate access broken → restore the prior sharing on that site; disable RSS (`Set-SPOTenantRestrictedSearchMode -Mode Disabled`) / remove RCD to revert containment.

Gate 6 — Copilot honors the controls (behavioral spot-check, where Copilot is licensed)

• **Test:** With a pilot user, confirm Copilot behavior against protected content: content under a "keep out of Copilot" label / DLP should **not** be summarized or cited; a cited response should carry the highest-priority sensitivity label of its sources; content on a site now access-restricted should no longer be reachable by that user's Copilot. *(Behavioral timing depends on service processing — allow for propagation.)*

• **Pass:** Copilot does not surface the protected/restricted content for a user without rights; label inheritance on citations is observed.

• **Fail / rollback:** Copilot still surfaces protected content → recheck the label encryption/usage rights, DLP location scope, and site access; do not proceed to broad enforce until this holds.

Gate 7 — Readiness go/no-go evidence complete (Step 8)

• **Test:** `AICOPILOT-ReadinessReport.ps1` compiles `Copilot Readiness – Tenant – GoNoGo` with the before/after oversharing, controls applied and their state, and residual risk. Stakeholders (2.8) review it.

• **Pass:** The record is complete and internally consistent; named approvers sign the go/no-go against the agreed criteria.

• **Fail / rollback:** Missing evidence or unmet criteria → return the relevant policy to simulation/test, remediate the gap, and re-report before broad rollout.

Regression / recurring validation

• Schedule the read-only chain `ReadinessScope` → `OversharingDiscovery` → `Validation` → `ReadinessReport` on the `Copilot Readiness Review – Tenant – Recurring` cadence (e.g. monthly). New sites, new broad shares, and drift in label coverage are caught before they become Copilot exposure. A rising oversharing signal or falling label coverage between runs is the trigger to re-remediate.

6. Troubleshooting — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

Common failure modes and resolutions, grouped by phase. Most issues are **licensing/availability**, **permissions/scope**, or **propagation timing** — the controls here are evolving and licensing-gated, so "verify in your tenant" is the recurring theme. Scripts are read-only or `-WhatIf`/simulation until `-Commit`, so diagnosis is safe.

Connections & authentication

• `Connect-IPPSSession` **fails or cmdlets missing (**`Get-Label` **not found).** Install the current **ExchangeOnlineManagement** module and connect with a modern-auth/MFA compliance admin. `AICOPILOT-ReadinessScope.ps1` reports the session state.

• `Connect-MgGraph` **connected but site/permission reads fail.** The Graph session lacks scope. Reconnect requesting at least `Sites.Read.All` (and `InformationProtectionPolicy.Read.All` where used); confirm an admin consented to the scopes. `Get-MgSitePermission` also requires sufficient rights — if it is denied, fall back to the **SharePoint DAG report** for the authoritative view.

• **"Access denied" opening a Purview/SharePoint blade.** Missing the least-privilege role (Requirement

2.2). Assign Information Protection Admin / the DLP role / SharePoint Administrator as appropriate; don't work around it with Global Admin as standing practice.

Licensing & availability (the most common blocker)

- **The DLP "Microsoft 365 Copilot" location is not present.** It is evolving and licensing-gated —

verify. If absent, do not fake it: keep "keep out of Copilot" content controlled with sensitivity **label encryption/usage rights** (which Copilot honors) plus **site access reduction** (Step 6), and record DLP-for-Copilot as pending. `AICOPILOT-Remediation.ps1 -Action DlpForCopilot` parameterizes the location and warns rather than assuming it.

- **SAM reports/controls (DAG, RCD, RSS, RAC, site access reviews) missing.** SharePoint Advanced

Management is not licensed/enabled (Requirement 2.6). Remediate access via native SharePoint site/ sharing settings and Graph permission review instead, and note the interim containment as unavailable.

- **Container labeling / mandatory labeling options not shown.** Both are licensing-dependent — verify.

Proceed with a **default label** (no mandatory enforcement) if mandatory labeling is unavailable.

- **DSPM for AI blade absent.** It is optional here — this solution remediates with or without it. Use the

discovery scripts and SharePoint DAG reports for the oversharing picture.

Discovery

- `Get-MgSite -Search "*"` **returns few or no sites.** The Graph module version or scope limits the

search; the endpoint/behavior can vary — **verify** the `Microsoft.Graph.Sites` module. Supply the in-scope site list from the SharePoint admin DAG export and pass targeted site IDs instead of a wildcard.

- **Every site shows** `OversharingSignal = review`**.** Permission reads were unavailable (scope). Use the

SharePoint DAG "Everyone Except External Users" / sharing-links reports as the authoritative source and reconcile.

- **Discovery and DAG report disagree.** The DAG report is the authoritative tenant view; the script is a

portable snapshot and may lag or lack permission depth. Trust the DAG report for the decision.

Labeling

- **Auto-labeling policy created but nothing appears labeled.** Correct — in **simulation** it labels

nothing; it only shows what it *would* label. Review the **simulation results** in the portal before enabling. If simulation shows nothing at all, the policy has no rules/conditions yet — add the sensitive info type → label conditions.

- **Simulation over-matches (false positives).** Tighten the conditions (more specific info types,

confidence/count thresholds) and re-simulate. Never enable an over-matching policy.

- **Copilot still summarizes content that carries a "protected" label.** The label likely classifies

without **encryption/usage rights** — Copilot only withholds content whose label denies the user usage rights. Add encryption with the appropriate usage rights to the label, and allow for propagation.

- **Cited Copilot responses carry an unexpected label.** Copilot inherits the **highest-priority** label

of the cited sources — check the label **priority order** in the taxonomy.

DLP for Copilot

- **Policy created but no test matches.** In **test** mode matches are simulated only; confirm the rule

scopes the **Copilot location** and the correct **label** condition. Allow processing time.

- **Cannot add the Copilot-location rule (**`New-DlpComplianceRule`**).** The Copilot DLP location may not be

available via PowerShell in your tenant — configure the rule in the **Purview DLP portal**, or use the label-encryption + access-reduction equivalent. Verify availability.

SharePoint access reduction & interim containment

- **Removing a broad grant broke legitimate access.** Restore the prior sharing on that site immediately

(rollback), then re-scope the reduction to a least-privilege **group** (RAC where licensed) so intended users keep access. Pilot access changes on the ring first.

- **RSS/RCD applied but Copilot/search still returns fenced content.** Allow for propagation; confirm RSS

mode (`Get-SPOTenantRestrictedSearchMode`) and that the site is on the correct RCD/allow list. RSS is an **interim allow-list (up to 100 sites)** — content outside the allow list is excluded, not the reverse; confirm the list semantics for your intent.

- **Treating RSS/RCD as the fix.** They are **stopgaps** — they hide, not reduce, access. Track fenced

sites as remediation debt and remove containment once the underlying access is actually corrected.

Enforcement & go/no-go

- `AICOPILOT-Remediation.ps1 -Action Enforce` **did nothing.** By design it previews without `-Commit`,

and the enforce mode-changes are commented until you match your exact policy names — set the specific policy identities to the enable mode and confirm the mode value in your tenant.

- **Go/no-go report shows a control "MISSING".** The policy name doesn't match, or it wasn't created.

Re-run the relevant remediation step with the exact artifact name, then re-report. Do not sign a go/no-go with missing evidence.

- **Oversharing signal did not drop after remediation.** Re-run discovery on the **same site set**;

confirm the access changes actually applied (propagation), and that new broad shares didn't appear. Persisting signal means more sites to remediate before broad Copilot rollout.

7. Best Practices — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

Sequence and safety

• **Remediate before you enable.** The whole point is to shrink oversharing *before* broad Copilot

rollout. Treat "enable Copilot" as the reward for passing the readiness gates, not the starting point. Where Copilot is already live, use interim containment (RSS/RCD) to buy time while you clean up.

• **Pilot every high-impact control in simulation/test/disabled first.** Auto-labeling in **simulation**,

DLP-for-Copilot in **test**, access changes on the **pilot ring** — validate, then enforce. Never enforce a new label/DLP/access change blind across the tenant.

• **One before-state, always.** Capture `Oversharing – Estate – Discovery` and the go/no-go baseline

before changing anything; it is both your evidence and your rollback target.

Labels are the primary Copilot control

• **Protect with encryption/usage rights, not just a name.** Copilot honors label **encryption and usage

rights** — a label that only classifies (no protection) does not stop Copilot from summarizing the content for anyone who can open it. For "keep out of Copilot" content, the label must deny the usage rights that would let Copilot extract it.

• **Get coverage up with a default label + auto-labeling.** A default label classifies new work;

simulation-mode auto-labeling catches sensitive content at rest. Together they close the unlabeled-sensitive gap that is the root of most Copilot exposure.

• **Mind label inheritance on citations.** Copilot-generated content that cites sources inherits the

highest-priority sensitivity label of those sources — design the taxonomy priority order so this produces sensible, not surprising, outcomes.

• **Container-label the collaboration surface.** Labeling SharePoint sites, Teams, and Groups controls

privacy, external sharing, and the default sharing link — reducing how oversharing gets created in the first place. *(Container labeling availability is licensing-dependent — verify.)*

Fix access, don't just hide it

• **RSS and RCD are stopgaps, not the fix.** Restricted SharePoint Search and Restricted Content

Discovery keep not-yet-cleaned sites out of Copilot/search **temporarily**. They mask the exposure; they do not reduce the underlying access. Track every RSS/RCD-fenced site as remediation debt and remove the containment once access is actually fixed.

• **Kill "Everyone Except External Users" broad grants.** EEEU and org-wide sharing are the classic

Copilot oversharing source. Prioritize sites where broad access overlaps unlabeled sensitive content.

- **Prefer least-privilege groups over ad-hoc links.** Where SAM is licensed, Restricted Access Control (limit a site to a named group) and site access reviews drive durable, owner-maintained cleanup.

Roles, separation of duties, and change control

- **Least-privilege, separated.** Information Protection Admin for labels, the DLP role for DLP, SharePoint Administrator for access — reserve Global/Compliance Admin for initial enablement. Reading posture and changing policy are different rights.
- **Everything through change control.** Enforcing a policy or restricting a site is a change-controlled step with an approver and a recorded rollback.

Governance boundary

- **You configure and evidence; governance decides.** What counts as "sensitive," what acceptable Copilot exposure is, what must be restricted or retained, and the final **go/no-go** are compliance/records/privacy/legal determinations. Keep those determinations with their owners and keep your role to method + evidence.

Operate it as a program, not a project

- **Re-measure on a cadence.** Oversharing regrows: new sites, new broad shares, new unlabeled content.

Run the recurring read-only chain and treat a rising oversharing signal or falling label coverage as a trigger to re-remediate before it becomes Copilot exposure.

- **Keep artifact names verbatim.** Reusing the `<Purpose> – <Scope> – <Stage>` names across portal, scripts, and reports keeps one artifact traceable end to end and makes the go/no-go auditable.
- **Verify availability every cycle.** DLP-for-Copilot, RSS, RCD, SAM reports, and container/mandatory labeling are evolving and licensing-gated — re-confirm they exist and behave as documented in *your* tenant rather than assuming last cycle's map still holds.

8. Deliverables Summary — Microsoft 365 Copilot Data-Protection Readiness (Microsoft Purview)

What you receive

A complete, self-guided package to **make your data safe before Microsoft 365 Copilot sees it** — oversharing discovery plus remediation with Microsoft Purview sensitivity labels, DLP, and SharePoint access controls — configured, piloted in simulation/test, validated, and evidenced with a go/no-go record. Delivered entirely with the Microsoft Purview portal, the Microsoft 365 / SharePoint admin centers, Security

& Compliance PowerShell (`Connect-IPPSSession`), and Microsoft Graph — no third-party tooling, no secrets in code.

Documentation set

Doc	Purpose
1. Solution Overview	What this delivers, how it differs from DSPM-for-AI telemetry, the remediation levers, and the Assess→Design→Configure→Pilot(simulate)→Validate→Expand model.
2. Requirements Guide	Each Copilot-readiness prerequisite (licensing, roles, auditing, taxonomy, in-scope estate + rollout ring, SAM controls, pilot/change-control, go/no-go ownership) with Verify / Implement, referencing the Purview category global requirements.
3. Implementation Guide	Ordered steps: confirm scope → discover oversharing → assess unlabeled sensitive → design → pilot labeling → pilot DLP-for-Copilot → reduce access + interim containment → validate → enforce + record go/no-go, each with pass/fail + rollback.
5. Testing & Validation	Seven pass/fail gates (scope, oversharing baseline, labeling, DLP-for-Copilot, access reduction, Copilot behavioral spot-check, go/no-go evidence) plus recurring validation.
6. Troubleshooting	Common failure modes across connections, licensing/availability, labeling, DLP-for-Copilot, oversharing discovery, and access controls, with resolutions.
7. Best Practices	Sequence & safety, labels as the primary Copilot control, fixing (not hiding) access, roles/SoD, the governance boundary, and running it as a program.
Executive Summary	One-page framing for decision-makers.

Automation — 5 PowerShell tools

All are **safe-by-default**: read-only, or `-WhatIf` / simulation / test until you pass `-Commit`. None contain credentials or secrets; they use interactive modern-auth (`Connect-IPPSSession` / `Connect-MgGraph`).

Script	Purpose	Default safety
`AICOPILOT-ReadinessScope.ps1`	Confirm connections, auditing state, and enumerate the available levers (labels, label policies, DLP, auto-labeling); write `Copilot Readiness – Tenant – Scope`.	Read-only

Script	Purpose	Default safety
`AICOPILOT-OversharingDiscovery.ps1`	Discover SharePoint/OneDrive oversharing (EEEU / org-wide / broad sharing links) and, with `-IncludeSensitive`, unlabeled-sensitive and label-coverage picture; write `Oversharing – Estate – Discovery` / `Unlabeled Sensitive – Estate – Assess`.	Read-only
`AICOPILOT-Remediation.ps1`	Create/manage the remediation controls: auto-labeling (**simulation**), DLP-for-Copilot (**test**), the site access-reduction list, and the simulation→enforce mode change — all gated behind `-Commit`.	`-WhatIf` / simulation-test
`AICOPILOT-Validation.ps1`	Confirm policy states (label published, auto-label in simulation, DLP in test) and re-read the pilot oversharing signal; evidence for the testing gates.	Read-only
`AICOPILOT-ReadinessReport.ps1`	Compile the go/no-go readiness record `Copilot Readiness – Tenant – GoNoGo` — before/after oversharing, controls + state, residual risk.	Read-only

Named artifacts (traceable end to end)

`Copilot Readiness – Tenant – Scope` · `Oversharing – Estate – Discovery` · `Unlabeled Sensitive – Estate – Assess` · `Default Labeling – Users – Pilot` · `Auto-Label Sensitive – Pilot – Simulation` · `DLP for Copilot – Pilot – Test` · `Site Access Reduction – Sites – Pilot` · `Copilot Readiness – Tenant – GoNoGo` · `Copilot Readiness Review – Tenant – Recurring`.

Outcome

Copilot oversharing **discovered, remediated, piloted, validated, and evidenced** — with a defensible go/no-go record — so Microsoft 365 Copilot surfaces only appropriate data. Regulatory, records, and legal determinations (including the final go/no-go decision) remain with your compliance, records, privacy, and legal functions; this package supplies the technical method and the evidence.

Assumptions & boundaries

- Feature availability (DLP-for-Copilot, RSS, RCD, SAM reports, container/mandatory labeling) is

licensing-/tenant-dependent and evolving — the guides flag every such item "verify in your tenant." Nothing here asserts a capability your plan may not include.

- Automation is PowerShell (Security & Compliance PowerShell / Graph); SharePoint-specific access

controls (RAC, RSS, RCD) are performed via the SharePoint admin center / SharePoint Online Management Shell per Microsoft's documented method, under SharePoint Administrator.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

AICOPILOT-OversharingDiscovery.ps1

AICOPILOT-ReadinessReport.ps1

AICOPILOT-ReadinessScope.ps1

AICOPILOT-Remediation.ps1

AICOPILOT-Validation.ps1